

System and Network Security

Dr. Ashok Kumar Das

IEEE Senior Member

Professor

Center for Security, Theory and Algorithmic Research
International Institute of Information Technology, Hyderabad

E-mail: *ashok.das@iiit.ac.in*

URL: <https://www.iiit.ac.in/faculty/ashok-kumar-das/>
<https://sites.google.com/view/iitkgpakdas/>

Intrusion Prevention and Detection

- An intrusion is the act of gaining unauthorized access to a system so as to cause loss or harm.
- **Examples:**
 - ▶ Unauthorized login to a system by illegally acquiring a password (through, for example, a password guessing attack).
 - ▶ Worm injections that use the system as a launch pad to spread and infect other machines.
 - ▶ Injection of spyware that passively monitors the activities of the user and replay this information back to the attacker (over the Internet, for example).
 - ▶ Flooding the host with spurious connection requests that attempt to exhaust the target's resources - processing power, memory, or communication bandwidth.

- Two ways of handling attempted intrusions are the following:
 - ▶ Intrusion prevention
 - ▶ Intrusion detection
- A real-life example is as follows:
 - ▶ Modern day ailments like diabetes and high blood pressure are known to be linked to lifestyle choices.
 - ▶ Preventive “treatment” for these ailments includes regular exercises, a stress-free life, and a diet rich in fruits and vegetables.
 - ▶ However, an individual who strictly follows these three practices cannot be guaranteed freedom from those medical problems.
 - ▶ We know the regular health checkups (especially for those beyond 50 years of age) can help prolong life.
 - ▶ In the current context, periodic monitoring of blood sugar levels and blood pressure are strongly recommended so that timely action can be taken if there is deviation from the norm.
 - ▶ The regular health check-ups are analogous to **“intrusion detection”**, while positive lifestyle choices are analogous to **“intrusion prevention”**.

Classification of Intruders

- **Masquerader:** An individual who is not authorized to use the computer and who penetrates a system access controls to exploit a legitimate user's account.
- **Misfeisor:** A legitimate user who accesses data, programs, or resources for which such access is not authorized, or who is authorized for such access but misuses his/her privileges.
- **Clandestine user:** An individual who seizes supervisory control of the system and uses this control to evade auditing and access controls or to suppress audit collection.
- The masquerade is likely to be an outsider; the misfeisor generally is an insider; and the clandestine user can be either an outsider or an insider.

Intrusion Techniques

- The objective of the intruder is to gain access to a system or to increase the range of privileges accessible on a system.
- Generally, this requires the intruder to acquire information that should have been protected.
- In most cases, this information is in the form of a user password.
- The password file can be protected in one of the two ways:
 - ▶ One-way encryption [password management, which is already discussed in the class]
 - ▶ Access control: Access to the password file is limited to one or a very few accounts.
- If one or both these countermeasures are in place, some effort is needed for a potential intruder to learn passwords.

Prevention

- Intrusion prevention anticipates various kinds of attacks and takes steps to forestall their occurrence.
 - ▶ Programmers should adopt practices that help or eliminate software vulnerabilities.
 - ★ The use of safe string manipulation functions in C/C++ and the use of parametrized SQL queries recommended to protect against buffer overflow and SQL injection attacks, respectively.
 - ★ Likewise, sanitizing user input from HTML forms is one preventive measure against cross-site scripting attacks. Note that Cross-site Scripting (XSS) refers to client-side code injection attack wherein an attacker can execute malicious scripts (also commonly referred to as a malicious payload) into a legitimate website or web application.

Prevention (Continued...)

- Another set of preventive measures may be taken by the computing system (hardware, compiler, or OS) to provide a second line of defense.
Buffer overflow vulnerability is a prime example.
Making the stack non-executable prevents one class of buffer overflow problems.
Using a canary value on the stack detects a buffer overflow and thus help prevent its possible exploitation.
- Many attacks can be prevented by properly configuring firewalls and timely application of software patches.
- One final aspect of intrusion prevention is “deterrence Hacking”, whether for fun or profit, is a criminal offense.

Intrusion Detection

- A system second line of defense is intrusion detection, and this has been the focus of much research in recent years.
- This interest is motivated by a number of considerations, including the following:
 - ▶ If an intrusion is detected quickly enough, the intruder can be identified and ejected from the system before any damage is done or any data are compromised.
Even if the detection is not sufficiently timely to preempt the intruder, the sooner that the intrusion is detected, the less amount of damage and the more quickly that recovery can be achieved.
 - ▶ An effective intrusion detection system (IDS) can serve as a deterrent, so acting to prevent intrusions.
 - ▶ Intrusion detection enables the collection of information about intrusion techniques that can be used to strengthen the intrusion prevention facility.

Intrusion Detection (Continued...)

- Intrusion detection is based on the assumption that the behavior of the intruder differs from that of a legitimate user in way that can be quantified.
- Of course, we can not expect that there will be a crisp, exact distinction between an attack by an intruder and the normal use of resources by an authorized user. Rather, we must expect that there will be some overlap.
- Although the typical behavior of an intruder differs from the typical behavior of an authorized user, there is an overlap in these behaviors.

Prevention versus Detection

Intrusion Detection (Continued...)

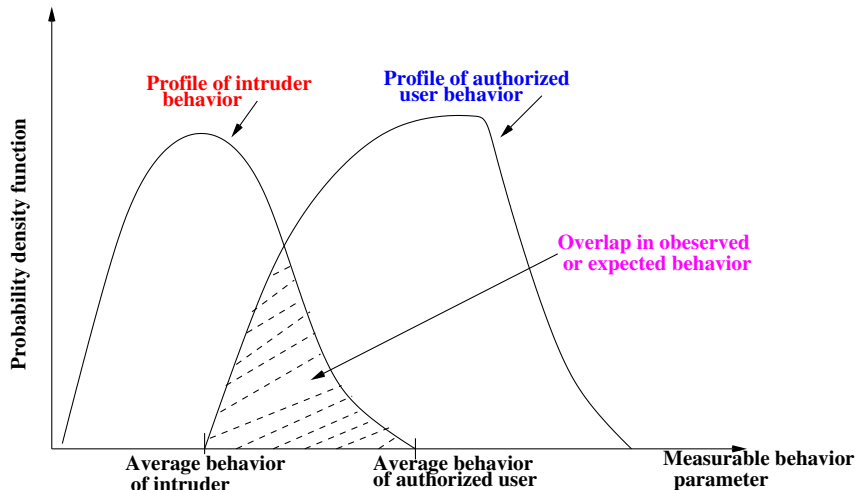


Figure: Profiles of behavior of intruders and authorized users

Intrusion Detection (Continued...)

- **False positive:** A loose interpretation of intruder behavior, which will catch more intruders, will also lead to a number of “false positives” or authorized users are identified as intruders. The probability of a false accept is called the **false accept rate (FAR)** or **fraud rate**.
- **False negative:** An attempt to limit false positives by a tight interpretation of intruder behavior will lead to an increase in “false negatives” or intruders are not identified as intruders. The probability of a false reject is called the **false reject rate (FRR)** or **insult rate**.

Intrusion Detection (Continued...)

- False negatives are riskier than false positives.
- If there was not an attack and the IDS picked it (false positive), it is not much of a harm.
- But if there was an attack and the IDS does not detect it (false negative), it can be disastrous.

Intrusion Detection (Continued...)

- An IDS performs the following three tasks:
 - ▶ First, it monitors “event of interest” occurring in the target system or in the network.

An event of interest may be

 - ★ A system call (a call made to the OS) to, for example, open a file containing sensitive data.
 - ★ Another event of interest may be the attempted establishment of a TCP connection from a specific IP address to a certain port.
 - ▶ An IDS generates a large amount data which it then analyzes and converts into valuable information to be used by system administrators.

The information gleaned may lead to conclusions such as “the source addresses in 90% of the packets received in the past 5 minutes are never-seen-before IP addresses”.
 - ▶ The IDS creates a database of “interesting events”. It raises an alert each time it observes any such event.

Prevention versus Detection

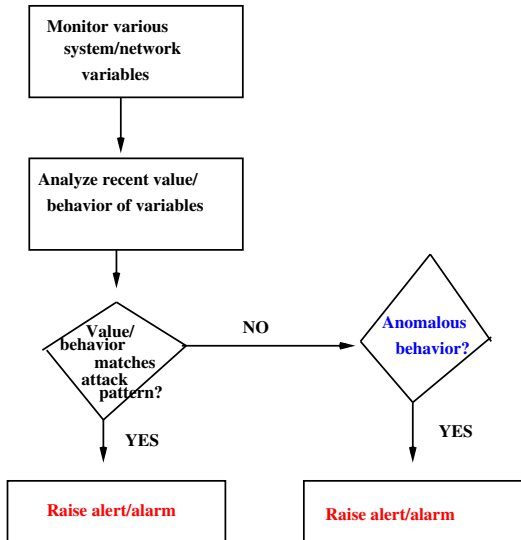


Figure: Tasks performed by an IDS.

Table: Events of interest to an IDS

Variable monitored	Event of interest	Possible attack
Number of accesses of specific file	Tenfold increase over norm	DoS attack
Login frequency to a particular account	Unusually high	Attempted break-in
Number of distinct source IP addresses of arriving packets	Very high	Worm attack
Ratio of ARP request packets to ARP response packets	$\gg 1$	Network scan to identify local active hosts
Ratio of TCP SYN packets to TCP FIN packets	$\gg 1$	Possible DoS attack

Table: Events of interest to an IDS (Continued...)

Variable monitored	Event of interest	Possible attack
Percentage of half-open TCP connections	Sudden surge	Possible DoS/DDoS attack
TCP header flags	Invalid combination	Port scan, OS fingerprinting
TCP connection establishment	Unused destination port	Attempt to find which services are open
Payload of incoming packets	Specific byte sequence present	Specific worm open
OS calls	Particular sequence of calls	Specific virus attack

Approaches to Intrusion Detection

Statistical anomaly detection

- Involves the collection of data related to the behavior of legitimate users over a period of time.
- The statistical tests are then applied to observed behavior to determine with a high level of confidence whether the behavior is not legitimate user behavior.

- ▶ **Chi Square test:** Compares observed frequencies to expected frequencies. It is for a population variance

The chi-square distribution results when ν independent variables with standard normal distributions are squared and summed. The formula for the probability density function of the chi-square distribution is

$$f(x) = \frac{e^{-\frac{x}{2}} x^{\frac{\nu}{2}-1}}{2^{\frac{\nu}{2}} \Gamma(\frac{\nu}{2})}, \text{ for } x \geq 0$$

where ν is the shape parameter and Γ is the gamma function. The formula for the gamma function is

$$\Gamma(n) = \int_0^{\infty} t^{n-1} e^{-t} dt$$

Statistical anomaly detection

- **t-Test:** Looks at differences between two groups on some variable of interest. It is for a population mean (variance unknown)
If we take a sample of n observations from a normal distribution, then the t -distribution with $\nu = n - 1$ degrees of freedom can be defined by the following probability density function:

$$f(x) = \frac{\Gamma(\frac{\nu+1}{2})}{\sqrt{\nu\pi}\Gamma(\frac{\nu}{2})} \left(1 + \frac{x^2}{\nu}\right)^{-\frac{\nu+1}{2}} \text{ for } x \in (-\infty, +\infty)$$

Statistical anomaly detection

- **F-Test:** It is for two population variances

The F -distribution is the ratio of two chi-square distributions with degrees of freedom ν_1 and ν_2 , respectively, where each chi-square has first been divided by its degrees of freedom. The formula for the probability density function of the F -distribution is

$$f(x) = \frac{\Gamma(\frac{\nu_1 + \nu_2}{2}) (\frac{\nu_1}{\nu_2})^{\frac{\nu_1}{2}} x^{\frac{\nu_1}{2} - 1}}{\Gamma(\frac{\nu_1}{2}) \Gamma(\frac{\nu_2}{2}) (1 + \frac{\nu_1 x}{\nu_2})^{\frac{\nu_1 + \nu_2}{2}}} \text{ for } x \geq 0$$

where ν_1 and ν_2 are the shape parameters and Γ is the gamma function.

Statistical anomaly detection (Continued...)

- (a) **Threshold detection:** This approach involves defining thresholds, independent of users, for the frequency of occurrence of various events.
- (b) **Profile based:** A profile of the activity of each user is developed and used to detect changes in the behavior of individual accounts.

Rule-Based Detection

- Involves an attempt to define a set of rules that can be used to decide that a given behavior is that of an intruder.
 - ▶ (a) Anomaly detection: Rules are developed to detect deviation from previous usage patterns.
 - ▶ (b) Penetration identification: An expert system approach that searches for suspicious behavior.

Statistical anomaly detection (Continued...)

- The foundation of the statistical anomaly detection approach is an analysis of audit records.
- Examples of metrics that are useful for profile-based intrusion detection are the following:
 - ▶ **Counter:** A non-negative integer that may be incremented but not decremented until it is reset by management action. Typically, a count of certain event types is kept over a particular period of time.
 - * **Examples:** The number of logins by a single user during an hour, the number of times a given command is executed during a single user session, the number of password failures during a minute.

Statistical anomaly detection (Continued...)

- **Gauge:** A non-negative integer that may be incremented or decremented.
Typically, a gauge is used to measure the current value of some entity.
* **Examples:** The number of logical connections assigned to a user application,
the number of outgoing messages queued for a user process.
- **Interval timer:** The length of the time between two events.
* **Example:** The length of time between successive logins to an account.
- **Resource utilization:** Quantity of resources consumed during a specified period.
* **Examples:** The number of pages printed during a user session,
the total time consumed by a program execution.

Statistical anomaly detection (Continued...)

- Given the above general metrics, various tests can be performed to determine whether current activity fits within acceptable limits. The following approaches that can be taken:
 - ▶ **Mean and standard deviation:** This test gives a reflection of the average behavior and its variability.
The use of mean and standard deviation is applicable to a wide variety of counters, timers, and resource measures.
 - ▶ **Multivariate:** This model is based on correlations between two or more variables.
Intruder behavior may be characterized with greater confidence by considering such correlations (for example, processor time and resource usage, or login frequency and session elapsed time).

Statistical anomaly detection (Continued...)

- **Markov process:** This kind of model is used to establish transition probabilities among various states.
Example: This model might be used at transitions between certain commands.
- **Time series:** This model focuses on time intervals, looking for sequences of events that happen too rapidly or too slowly.
A variety of statistical tests can be applied to characterize abnormal timing.

- In a SYN flood attack, the victim sees a dis-appropriate number of SYN packets compared to FIN packets.
 - ▶ By a SYN packet, we mean any incoming packet with the SYN flag set.
Recall that such a packet is a TCP connection request packet.
 - ▶ Likewise, FIN and RST packets are, respectively, those with the FIN and RST flags set.
 - ▶ A FIN packet is sent by the side that wishes to terminate the TCP connection. If other party agrees to termination, it responds with its own FIN packet. Thus, SYN and FIN packets usually occur in pair.

- TCP connections that terminate normally involve one SYN packet (from the client) and a corresponding FIN packet to initiate or confirm termination of a connection.
The total number of incoming SYN packets should equal the number of incoming FIN packets.
- In the event of a connection being abort, an RST packet takes the place of the FIN.
In most cases, the number of RST packets is a small fraction of the number of FIN packets, so we ignore them in our analysis.

DDoS Detection (Continued...)

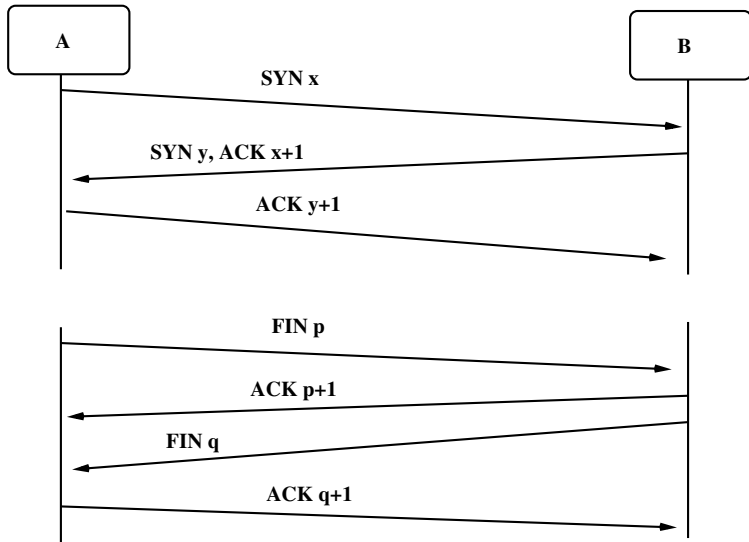
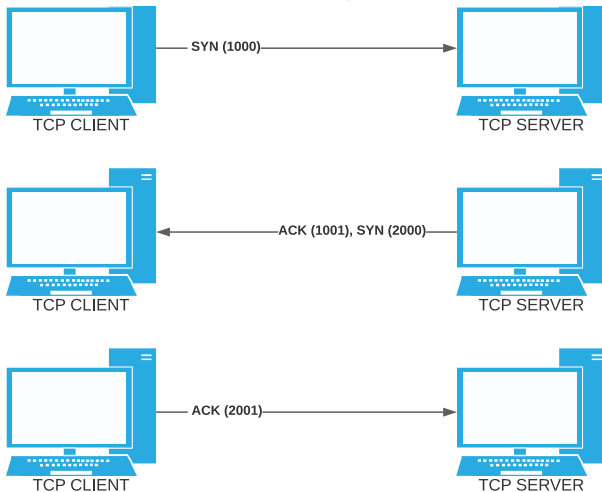


Figure: TCP connection establishment and termination

DDoS Detection (Continued...)



3-Way Handshake

Figure: An example of TCP connection establishment

- **Haining Wang, Danlu Zhang, Kang G. Shin: Change-Point Monitoring for the Detection of DoS Attacks. *IEEE Transactions on Dependable and Secure Computing*, Vol. 1, No. 4, pp.193–208, 2004.**

- Define the following variables:

- ▶ S_i = # of SYN packets arrivals in the i^{th} observation interval, T_i
- ▶ F_i = # of FIN packets arrivals in the i^{th} observation interval, T'_i
- ▶ D_i = Normalized difference between # of SYN and FIN packets in the i^{th} observation interval, that is,

$$D_i = \frac{S_i - F_i}{F_i}.$$

- ▶ τ_1, τ_2, τ_3 = thresholds for detection

- Consider the time series:

$$D_1, D_2, D_3, \dots$$

Detection Algorithm 1

- Raise an alert, if the most recently computed detection variable D_i exceeds the threshold τ_1 , that is,

$$D_i > \tau_1.$$

- The IDS may raise many alarms since it bases its decision on point values.

Detection Algorithm 2

- Raise an alert, if the “smoothed average” of the previous values of D exceeds the threshold τ_2 .
- This approach uses the well-known technique of exponential smoothing.
- The decision variable at the end of the i^{th} observation interval is the smoothed average, S_i computed using

$$\begin{aligned} S_i &= \alpha D_i + (1 - \alpha) S_{i-1}, 0 < \alpha < 1, \\ S_0 &= 0, \end{aligned}$$

where α is known as “smoothing constant”.

Detection Algorithm 2 (Continued...)

- Thus,

$$\begin{aligned}S_i &= \alpha D_i + (1 - \alpha) S_{i-1} \\&= \alpha D_i + (1 - \alpha) [\alpha D_{i-1} + (1 - \alpha) S_{i-2}] \\&= \alpha D_i + \alpha(1 - \alpha) D_{i-1} + (1 - \alpha)^2 S_{i-2} \\&\vdots \\&= \alpha D_i + \alpha(1 - \alpha) D_{i-1} + \alpha(1 - \alpha)^2 D_{i-2} + \dots\end{aligned}$$

- For example, for $\alpha = 0.40$, we get,

$$S_i = 0.40 D_i + 0.24 D_{i-1} + 0.14 D_{i-2} + \dots$$

Detection Algorithm 2 (Continued...)

- The decision variable S_i is thus a “weighted sum” of D_i , D_{i-1} , D_{i-2} , $\dots$ which degrades weights assigned to earlier values of D .
- Thus, “earlier” values of D count less.
- An alarm will be raised if $S_i > \tau_2$.

Detection Algorithm 2 (Continued...)

Observations

- The value of τ_2 is set based on empirical data.
 - ▶ If it is too low, it will result in many “false positives”.
 - ▶ If it too high, it will result in “false negatives”.
- Another design parameter is the “smoothing” constant α .
 - ▶ If a value close to 1 is selected, it will give dis-appropriate importance to the most recent value of D_i .
 - ▶ If the limiting case of $\alpha = 1$, this algorithm reduces to Detection Algorithm 1.
 - ▶ If the close of zero α , the more even are the weights assigned to all values of D_i .

Detection Algorithm 3

- Define a “modified cumulative sum” of previous values of D .
- Raise an alert, if this value exceeds a threshold τ_3 .
- This method makes use of a technique, called the sequential change point detection
[M. Basseville and I. V. Nikiforov, “Detection of Abrupt Changes: Theory and Application, Pentice Hall, 1993.]

An anomaly detection system (Continued...)

Detection Algorithm 3 (Continued...)

- During normal operation, the number of FIN packets will balance out the number of SYN packets, and hence $D_i = \frac{S_i - F_i}{F_i}$ will be close to 0.
- Let u be an upper bound on the mean of D_i during the normal operations.
- Let D'_i be a shifted version of D_i , that is,

$$D'_i = D_i - u.$$

- The decision variable M_i used here is defined by

$$M_i = (M_{i-1} + D'_i)^+,$$

$$M_0 = 0.$$

- The notation x^+ is defined as follows:

$$x^+ = \begin{cases} x, & \text{if } x > 0 \\ 0, & \text{otherwise.} \end{cases}$$

Detection Algorithm 3

- The IDS sounds an alert at the end of j^{th} interval, if

$$M_j > \tau_3,$$

where τ_3 is a threshold determined empirically.

- With Detection Algorithm 3 (cumulative sum method), the false positives and false negatives encountered with Detection Algorithm 1 are both avoided.

Thank You !!!